CVEs más relevantes de la semana

Del 13/10/2026 al 20/10/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2020-37282

Descripción: office-converter through 1.0.2 contains an OS command injection vulnerability that allows attackers to execute commands by supplying a crafted fileName to generatePdf() or generateHtml(). Attackers can embed $(...), backticks, or a closing quote with shell metacharacters in the file name, which is concatenated into an unoconv command run via child_process.exec(), executing commands with Node.js...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-110635

Descripción: webp-converter before 3.0.0 contains an OS command injection vulnerability in src/webpconverter.js helpers that run libwebp binaries via execFile with shell enabled. Attackers controlling file names or option strings passed to cwebp, dwebp, gwebp, or webpmux functions can inject shell metacharacters to execute OS commands as the Node.js process.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-110640

Descripción: Whisper-node through 1.1.1 contains an OS command injection vulnerability that allows attackers to execute commands by supplying crafted filePath or whisperOptions.language values to whisper(). Attackers can inject shell metacharacters or $() substitution into the command string built by createCppCommand() and run via shelljs exec() to execute commands with Node.js process privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-89068

Descripción: Missing critical step in authentication vulnerability in Progress MOVEit Transfer (LDAP module).

This issue affects MOVEit Transfer: before 2025.1.6 and from 2026.0.0 before 2026.0.4.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-304

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-89073

Descripción: Insufficient Session Expiration vulnerability in Progress MOVEit Transfer.

This issue affects MOVEit Transfer: before 2025.1.6 and from 2026.0.0 before 2026.0.4.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-613

Tecnología: No especificado

Publicado el: 2026-10-14

CVE-2026-101307

Descripción: When the PCM sample array needs to grow, the RACK stack doubles a 16-bit allocation counter. Repeated doublings caused the counter to wrap to zero, resulting in a near-zero-length allocation followed by a copy of the existing samples into the undersized buffer. A remote peer can trigger the expansion by sending a sufficient number of ACKs on an established connection.

A remote attacker who c...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-111094

Descripción: In JetBrains TeamCity before 2026.2, 2026.1.4, 2025.11.8 remote code execution via a whitelist bypass in the build messages protocol was possible

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-109383

Descripción: undici is an HTTP client library for Node.js. In versions 4.0.0 through 6.29.0, 7.0.0 through 7.30.0, and 8.0.0 through 8.12.1, its Agent dispatcher passes its constructor options through a JSON-based deep clone before forwarding them to each per-origin pool, and because JSON cannot represent functions, a caller-supplied tls option containing a checkServerIdentity callback is silently dropped b...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-295

Tecnología: No especificado

Publicado el: 2026-10-15



CVE-2026-109829

Descripción: undici is an HTTP client library for Node.js. In versions 7.0.0 through 7.30.0 and 8.0.0 through 8.12.1, when an originless Agent composes the redirect and cache interceptors in that order with a shared cache store, the cache builds its key from the original request URL before the redirect handler changes the origin, so a response produced after a cross-origin redirect is stored under the origi...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-346

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-102764

Descripción: The vulnerability exists within internal components of BeyondTrust's Remote Support product. The components did not adequately validate the origin of the messages it received. Under the right conditions, this could allow an attacker to perform file operations on the appliance.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-111281

Descripción: Jooan JA-A12 IP cameras with firmware 009_20171107 and 05.02.31.105 contain a remote code execution vulnerability that allows unauthenticated attackers to run root commands via hard-coded credentials. Attackers send singleCMD=SetDiagMode to /goform/SingleHandlebyCommand with an attacker-chosen authserverip and authcode, making the jooandiag daemon execute their commands through /bin/sh, giving ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-798

Tecnología: No especificado

Publicado el: 2026-10-15

CVE-2026-111375

Descripción: FreeRDP from 3.0.0 before 3.32.0 contains an out-of-bounds read vulnerability in the Windows RAIL client that allows malicious RDP servers to trigger heap over-reads by sending non-NUL-terminated window titles. Attackers can send a full-length WINDOW_ORDER_FIELD_TITLE update that wf_rail_window_common passes to SetWindowTextW, corrupting titles or crashing the client.

CVSS: 4.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:L

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-10-16

CVE-2026-111643

Descripción: Misaka Danmu Server through 2.8.9 contains an authentication bypass vulnerability that allows unauthenticated attackers to write arbitrary configuration keys via the unprotected POST /api/ui/config-history/rollback endpoint. Attackers can set the ipWhitelist key to their own /32 address, or alter trustedProxies and webhookApiKey, to access every protected endpoint as the administrator.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-16

CVE-2026-111693

Descripción: DataBuff ai-apm-web through 0.1.10 contains a hard-coded default credentials vulnerability that allows unauthenticated attackers to gain administrator access using the built-in admin/Databuff@123 account. Attackers can POST these credentials to /webapi/api/v1/auth/login to obtain an administrator token and access all protected /webapi routes.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1392

Tecnología: No especificado

Publicado el: 2026-10-16

CVE-2026-111704

Descripción: LangChat through commit 2a6285a contains a missing authentication vulnerability that allows unauthenticated remote attackers to access REST controllers because no Sa-Token interceptor is registered. Attackers can query /api/v1/auth/users to read plaintext passwords, retrieve LLM provider API keys, create super-admin accounts, and modify or delete data.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-16

CVE-2026-112370

Descripción: A vulnerability was found in H3C Magic NX15 100R017. This issue affects the function sub_416874 of the file /usr/bin/usrlist. Performing a manipulation results in os command injection. Remote exploitation of the attack is possible. The exploit has been made public and could be used. The vendor was contacted early about this disclosure.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-10-19

CVE-2026-113390

Descripción: A flaw has been found in DrayTek Vigor2960 1.5.1.6 Revision 8218. Affected by this issue is the function sub_182B0 of the file /cgi-bin/mainfunction.cgi of the component CGI Interface. This manipulation of the argument usefile/usescript/option causes os command injection. Remote exploitation of the attack is possible. The exploit has been published and may be used. The vendor explains: "2960 1....

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-113678

Descripción: Froxlor before 2.3.15 contains a symlink following vulnerability in Statistics::makeChownWithNewStats that allows authenticated customers to take ownership of arbitrary host directories by abusing the root-run traffic cron. Attackers can replace the goaccess statistics directory in their document root with a symlink, causing chown -R to hand root-owned trees to them and enabling root escalation.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-59

Tecnología: No especificado

Publicado el: 2026-10-20

CVE-2026-113802

Descripción: Wavlink WL-WN530BE1-A firmware through M30BE1_V251117 contains an OS command injection vulnerability in the sub_23B54 function of the ioos binary, which passes the unsanitized file_id parameter of /protocol.csp?opt=ovpn_file requests with type=del to popen(). A remote unauthenticated attacker can send a forged IP-FROM: 127.0.0.1 header to bypass login and execute arbitrary commands as root.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-20

Resumen del Reporte

CVEs analizados: 19

Promedio CVSS: 8.96

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat

